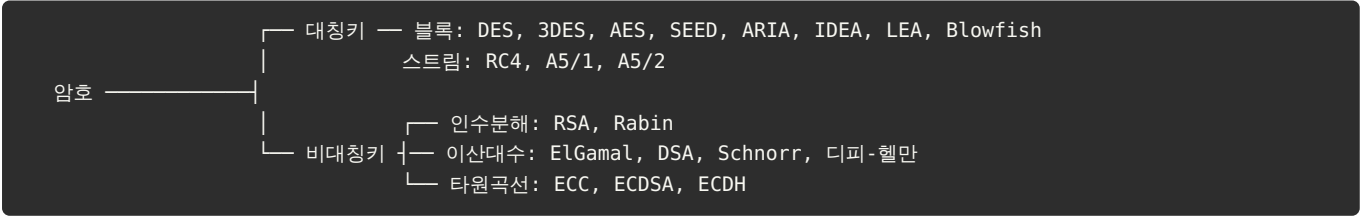


- **위협(Threat):** 자산에 손실을 가져올 수 있는 사건
- **취약점(Vulnerability):** 위협이 실현되도록 하는 약점
- **위험(Risk) = 자산 × 위협 × 취약점 / 통제**

제2장 암호학 기초 및 고전 암호

2.1 암호 알고리즘 분류표



⚠ **빈출 함정:** - 디피-헬만은 비대칭키(키 교환) — 2022 국가직 3번 - ECC는 비대칭키(타원곡선) — 2025 지방직 9번 - A5/1은 스트림 대칭키 — 공개키 아님

2.2 고전 암호

방식	특징	예
시저	단일 치환, k=3	단일문자(monoalphabetic)
비즈네르	다중 치환, 키워드 반복	다중문자(polyalphabetic)
플레이페어	2글자 단위	단일문자
아핀	$E(x)=ax+b \bmod 26$	단일문자

⚠ **빈출 함정:** 2025 지방직 16번 — 다중문자 = 비즈네르 + 힐(Hill) 만 해당. 시저·플레이페어·아핀은 단일문자.

제3장 대칭키 암호

3.1 DES vs AES

항목	DES	3DES	AES
블록크기	64	64	128
키크기	56	112/168	128/192/256
라운드	16	48	10/12/14
구조	Feistel	Feistel	SPN
안전성	취약	보통	안전

AES 라운드 수 공식: 128bit→10, 192bit→12, 256bit→14 (2024 국가직 16번)

3.2 AES 라운드 연산

- 마지막 라운드는 MixColumns 생략 (2022 국가직 7번 — “모든 라운드에서 4개 연산 수행”이 X)
- 연산 4가지: SubBytes, ShiftRows, MixColumns, AddRoundKey

3.3 블록 암호 운영 모드 [핵심표]

모드	패턴노출	병렬화(암)	병렬화(복)	오류전파	IV/Nonce	특징
ECB	O	O	O	해당 블록	불필요	같은 평문 →같은 암호문 (위험)
CBC	X	X	O	C ₁ 오류→P ₁ ,P ₂	IV 필요	직렬 암호화
CFB	X	X	O	C 오류→해당+다음	IV 필요	스트림화
OFB	X	X	X	오류 비전파	IV 필요	비트 오류 전파 X
CTR	X	O	O	해당 블록	Nonce+카운터	병렬화 완벽

△ **빈출 핵심**: - “복호화 시 $P_i = D_K(C_i) \oplus IV$, $P_i = D_K(C_i) \oplus C_{i-1}$ ” → **CBC** (2025 국가직 20번) - “ $C_i = E_K(C_{i-1}) \oplus P_i$ ”는 CFB 식. CBC는 “ $C_i = E_K(P_i \oplus C_{i-1})$ ” - “병렬처리 가능 + 카운터 암호화 후 XOR” → **CTR** (2022 국가직 6번) - “오류 전파 X + 평문 패턴 동일” → **OFB** (2025 지방직 11번)

제4장 비대칭키 암호 (공개키)

4.1 RSA

키 생성: 1. 소수 p, q 선택 $\rightarrow n = p \cdot q$ 2. $\phi(n) = (p-1)(q-1)$ 3. $\gcd(e, \phi(n))=1$ 인 공개키 e 선택 4. $d \cdot e \equiv 1 \pmod{\phi(n)}$ — 개인키 d

암복호화: - 암호화: $C = M^e \bmod n$ - 복호화: $M = C^d \bmod n$ - 안전성: **큰 수의 소인수분해 어려움**

전자서명 (RSA): - 서명: $S = M^d \bmod n$ (송신자 개인키 사용) - 검증: $M = S^e \bmod n$ (송신자 공개키 사용)

⚠ **빈출 함정:** 2026 국가직 2번 — “공개키로 암호화한 메시지는 전자서명 기능을 제공한다”는 **X**. 전자서명은 **개인키로 서명**.

4.2 디피-헬만 키 교환

공개: 소수 p , 원시근 g
A: 비밀 $a \rightarrow A = g^a \bmod p$ 전송
B: 비밀 $b \rightarrow B = g^b \bmod p$ 전송
공유키 $K = B^a \bmod p = A^b \bmod p = g^{(ab)} \bmod p$

- 안전성: **이산대수 문제**
- 취약점: **MITM 공격에 취약** (인증 없음) $\rightarrow$ 인증 추가한 STS, MQV 사용

4.3 곱셈에 대한 역원 (Z_n)

Z_n 에서 a 의 곱셈역원이 존재 $\iff \gcd(a, n) = 1$

예시 ($Z_{26}, n=26=2 \times 13$): - 역원 존재 X: 26과 공약수 가진 짝수, 13의 배수 $\rightarrow$ **2, 4, 6, 8, 10, 12, 13, 14, 16, 18, 20, 22, 24** - 역원 존재 O: **1, 3, 5, 7, 9, 11, 15, 17, 19, 21, 23, 25**

⚠ **2026 국가직 15번:** Z_{26} 에서 곱셈역원이 **없는** 원소 = **13** (정답 ③). 7, 11, 23은 모두 $\gcd=1$.

4.4 비대칭키 알고리즘 정리표

알고리즘	기반 문제	용도
RSA	소인수분해	암호화 + 서명
ElGamal	이산대수	암호화 + 서명
디피-헬만	이산대수	키 교환
DSA/DSS	이산대수 (NIST FIPS 186)	서명 전용
Schnorr	이산대수, $q p-1$	서명
ECC	타원곡선 이산대수	암호화 + 서명
ECDSA	타원곡선	서명
배낭암호	NP-완전	암호화 (취약 판명)

제5장 해시함수와 전자서명

5.1 해시함수 특성 (3가지)

- 역상 저항성**(Preimage Resistance): h 가 주어졌을 때 $H(x)=h$ 인 x 찾기 불가능 — 일방향성
- 제2 역상 저항성**(Second Preimage): x 가 주어졌을 때 $H(y)=H(x)$ 인 $y \neq x$ 찾기 불가능 — 약충돌
- 충돌 저항성**(Collision Resistance): $H(x)=H(y)$ 인 $x \neq y$ 쌍 찾기 불가능 — 강충돌

△ **빈출**: 2024 지방직 5번 — “임의 크기 → 고정 길이”(가변 X), “역상 찾기 계산적 불가능”, “효율적 계산 가능”, “충돌 쌍이 존재함은 비둘기집 원리상 사실이지만 찾기가 어려움”

5.2 주요 해시 알고리즘

알고리즘	출력	블록	라운드	비고
MD5	128	512	64	취약
SHA-1	160	512	80	취약
SHA-224/256	224/256	512	64	안전
SHA-384/512	384/512	1024	80	안전
SHA-3	가변	가변	-	Keccak 기반

△ **2023 지방직 15번**: SHA-512 라운드 **80**, 블록 **1024 bit**

5.3 생일 역설 (Birthday Paradox)

- n -bit 해시에서 충돌을 찾는 작업량 $\approx 2^{n/2}$
- 예: SHA-256 $\rightarrow 2^{128}$ 작업이면 충돌
- 단순 무차별 대입은 2^n

5.4 HMAC

$HMAC(K, M) = H((K^+ \oplus opad) || H((K^+ \oplus ipad) || M))$

- K^+** : K 를 오른쪽에 0 패딩 $\rightarrow$ 해시 입력 블록 크기와 동일 (왼쪽 패딩 X) △
- $ipad$** = 0x36 반복, **$opad$** = 0x5C 반복
- 해시 함수는 MD5, SHA-1, SHA-512 등 가변 선택 가능

△ **2025 국가직 19번**: “ K^+ 는 K 의 왼쪽에 0을 패딩”이 X (실제는 오른쪽)

5.5 전자서명 보안 요소

- 제공: ① 메시지 무결성 ② 서명자 인증 ③ 부인방지
- 제공 X**: 메시지 기밀성 (서명 $\neq$ 암호화)

△ **2025 국가직 2번**: “메시지 기밀성”이 전자서명이 제공하지 않는 것

5.6 송신자 A가 B에게 기밀 문서 전송 (하이브리드)

$A \rightarrow B: E_{KS}(M) || E_{KpuB}(KS)$
세션키로 본문 암호화 || B 공개키로 세션키 암호화

- 무결성·서명 추가 시: $+ E_{KprA}(H(M))$
- △ **빈출**: 2023 국가직 15번 — KS =세션키, $KpuB=B$ 공개키 ($X: KprA, KpuA$ 만 쓰면 기밀성 X)

제6장 PKI와 인증

6.1 PKI 구성요소

- **CA**(인증기관): 인증서 발급·관리·폐기
- **RA**(등록기관): 사용자 신원 확인
- **인증서 저장소**(Repository): 인증서 공개 저장
- **CRL**(인증서 폐기 목록), **OCSP**(실시간 폐기 확인)

6.2 X.509 인증서 폐기 사유

- 키 손상(keyCompromise)
- CA 손상(cACompromise)
- 소속 변경(affiliationChanged)
- 권한 변경(superseded)
- 운영 중단(cessationOfOperation)
- 보류(certificateHold)

6.3 Kerberos

- **MIT 개발**, 대칭키 기반 **티켓** 발급 시스템
- 구성: KDC = AS(Authentication Server) + TGS(Ticket Granting Server)
- 세션키 분배 + 기밀성 제공 가능
- **v5는 nonce(비표) 사용** → 재생 공격 방어 △
- △ **2024 지방직 6번**: “v5는 nonce를 사용하지 않아 재생공격 취약”이 X

6.4 SET 이중 서명

목적: 상점에는 주문정보만, 은행에는 지불정보만 보이게 (분리 + 연결)

듀얼 서명 = $H(H(OI) || H(PI))$ 를 소비자 개인키로 서명

금융기관(은행)의 검증에 필요한 것: - ① 소비자의 **공개키** (서명 검증) - ② **주문 정보의 해시 H(OI)** (직접 못 봄) - ③ **지불 정보(PI)** → 해시 계산 - X 상점의 공개키 (불필요)

△ **2023 지방직 14번**: 정답 ③ 상점의 공개키

6.5 생체 인증 지표

- **FAR**(False Acceptance Rate, 오수락률): 권한 없는 사람이 **성공**
 - **FRR**(False Rejection Rate, 오거부율): 권한 있는 사람이 **실패** △ (자주 헛갈림)
 - **EER**(Equal Error Rate): FAR=FRR 교차점, 낮을수록 우수
-

제7장 시스템 보안

7.1 접근통제 모델 [핵심표]

모델	정책	특징	분류
DAC(임의적)	소유자 결정	UNIX 권한, ACL	임의적
MAC(강제적)	시스템 결정, 보안등급	BLP, Biba, Lattice	강제적
RBAC(역할기반)	역할에 권한	직무 분리	-

BLP (Bell-LaPadula) — 기밀성 중심

- **No Read Up** (단순 보안 속성): 낮은 등급은 높은 등급 읽기 X
- **No Write Down** (* 속성): 높은 등급은 낮은 등급 쓰기 X
- 군사용

Biba — 무결성 중심 (BLP 반대)

- **No Read Down**: 높은 무결성은 낮은 무결성 읽기 X
- **No Write Up**: 낮은 무결성은 높은 무결성 쓰기 X

Clark-Wilson — 상업적 무결성

- 잘 구성된 트랜잭션(Well-formed Transaction)
- **직무 분리**(Separation of Duty)
- 제약 받는 데이터 항목(CDI)에 대한 무결성 검증

⚠ 2025 국가직 4번: “상업 환경의 데이터 무결성, 정형화된 트랜잭션, 직무 분리, 제약받는 데이터 항목 무결성 검증” → Clark-Wilson

Chinese Wall — 이해 충돌 방지

- 금융권에서 사용. 한 회사를 본 사람은 경쟁사를 못 봄

7.2 운영체제 구성요소 역할

- **메모리 관리**: 적합성 점검 후 할당
- **프로세스 관리**: 생성·실행·종료, **스케줄링**
- **파일 관리**: 디렉터리·파일 관리
- **인터럽트**: 예기치 못한 사건 처리

⚠ 2022 국가직 17번: “파일 관리가 작업 스케줄링한다”는 X (스케줄링은 프로세스 관리)

7.3 리눅스 권한과 파일

/etc/passwd 구조

```
root : x : 0 : 0 : root : /root : /bin/bash
사용자ID : 패스워드(x) : UID : GID : 설명 : 홈디렉토리 : 셸
```

⚠ 2024 국가직 9번: 마지막 필드는 **셸 경로** (패스워드 저장 X)

/etc/shadow 포함 항목

- 사용자 계정명, **솔트(salt)**, 해시된 패스워드, **기준일(epoch) 이후 일수**, 만료일 등
- **포함 X**: 대칭키 암호 알고리즘 종류 ⚠

umask와 기본 권한

- **파일 기본 권한** = 666 - umask
- **디렉토리 기본 권한** = 777 - umask
- 예: umask 027 → 디렉토리 = 777-027 = **750 = drwxr-x-** ⚠

7.4 윈도우 보안

- **SAM**(Security Accounts Manager): 사용자 정보 DB
- **SID**(Security Identifier): 사용자 고유 식별자, ACL에서 권한 결정 기준
- **SRM**(Security Reference Monitor): 접근 허용/거부 결정 + 감사

⚠ **2025 지방직 7번**: SAM과 SRM 사이의 사용자 식별자 = **SID**

윈도우 레지스트리 최상위 키 (5개)

키	역할
HKEY_LOCAL_MACHINE	HW/SW 설정
HKEY_CLASSES_ROOT	파일 타입 연결
HKEY_CURRENT_USER	현재 사용자 설정
HKEY_USERS	모든 사용자
HKEY_CURRENT_CONFIG	현재 HW 프로파일 (성능 데이터 X)

⚠ **2023 지방직 17번**: “HKEY_CURRENT_CONFIG가 실시간 성능 데이터”는 X (그건 HKEY_PERFORMANCE_DATA, 윈도우 NT 이전)

7.5 스택 버퍼 운용 (함수 반환)

순서: (나) → (다) → (가) → (라) 1. SP를 FP 값으로 복원 2. 이전 FP 값 pop, FP를 호출자 P의 스택 프레임으로 설정 3. **return address pop** 4. 호출 이후 명령 실행

스택 오버플로 방어: - 카나리(canary), ASLR, NX 비트, **스택에서 코드 실행 차단** (실행 허용은 X)

7.6 악성코드 분류

유형	특징
바이러스	숙주 필요, 자기 복제
웜	숙주 불필요, 네트워크 자가 전파
트로이목마	정상 위장, 백도어
루트킷	관리자 권한 + 은폐
랜섬웨어	1989년 등장, GPCode (2006), 공격자 개인키 모르면 복호화 불가
스파이웨어	정보 수집·전송
봇	명령에 따라 DDoS 등 수행
애드웨어	광고 표시
로직볼	조건 충족 시 작동
키로거	키 입력 기록
백도어	비밀 통로 유지

제8장 네트워크 보안

8.1 OSI 7계층과 보안 프로토콜

계층	프로토콜	보안 프로토콜
응용	HTTP, SMTP, FTP, DNS	PGP, S/MIME, HTTPS, SSH
표현	-	-
세션	-	-
전송	TCP, UDP	SSL/TLS
네트워크	IP, ICMP	IPSec
데이터링크	Ethernet	WPA, WPA2, WPA3
물리	-	-

8.2 TCP/UDP

TCP 특성

- **연결 지향**(Connection-oriented), 3-way handshake (SYN→SYN+ACK→ACK)
- 신뢰성(순서, 재전송) 보장
- 흐름·혼잡 제어

⚠ 2022 국가직 2번: “비연결 지향”이 X

UDP 헤더 구성요소

- 발신지 포트, 목적지 포트, 길이, 체크섬
- **포함 X**: 순서 번호 △ (그건 TCP)

8.3 IPv4 vs IPv6

항목	IPv4	IPv6
주소	32 bit	128 bit
표기	점10진	콜론16진
주소 종류	유니/멀티/ 브로드캐스트	유니/멀티/ 애니캐스트 (브로드캐스트 X) △
보안	옵션	IPSec 필수 통합
헤더	가변	고정 40 byte

8.4 IPSec [핵심표]

프로토콜	인증	기밀성	무결성
AH	O	X	O
ESP	O (선택)	O	O

모드: - **전송 모드**: IP 페이로드만 보호, 원본 IP 헤더 유지 - **터널 모드**: 원본 IP 패킷 전체 + 새 IP 헤더 추가 (VPN)

키 관리: **IKE**(Internet Key Exchange, ISAKMP 사용)

⚠ 2026 국가직 17번: “기밀성·발신 인증·비연결 무결성 제공” + “데이터 암호화 위해 대칭키” → **ESP + 대칭키**

⚠ 2023 지방직 7번: “ESP는 원래 IP 패킷 전부 + ESP 헤더/트레이일러 **모두** 암호화” X. ESP 인증 데이터(ICV)는 암호화 대상 아님. 트레이일러는 암호화 대상.

8.5 SSL/TLS

SSL/TLS 프로토콜 구조

응용 계층

| Handshake | ChangeCipherSpec | Alert | (Record 상위)

| Record Protocol | ← 단편화·압축·MAC·암호화·헤더 추가

TCP

Record 프로토콜 처리 순서 [△](#)

단편화 → 압축(옵션) → MAC 추가 → 암호화 → 헤더 추가 (2026 국가직 4번)

Handshake 프로토콜 목적

- 인증서 확인 ✓
- 세션키 생성·교환 ✓
- 응용 데이터 전송 X (Record 담당)
- 세션 활성 상태 유지 X

ChangeCipherSpec

- 협상한 매개변수를 “대기→활성”으로 전환
- 클라이언트·서버 양쪽이 서로에게 전송

Alert 프로토콜

- 오류·경고 전달 (Record 상위 프로토콜)

[△ 2024 국가직 17번](#): 단편화·압축·MAC·암호화 수행 → **Record**

8.6 SSH (RFC 4251)

3개 프로토콜 구성 (TCP 위에서 동작):

1. 전송 계층 프로토콜: 서버 인증, 기밀성, 무결성, 선택적 압축
2. 사용자 인증 프로토콜: 클라이언트(사용자)를 서버에게 인증
3. 연결 프로토콜: 암호화된 연결 위에 여러 논리적 채널 다중화

[△ 2026 국가직 10번](#): SSH 구성요소가 아닌 것 = **Handshake 프로토콜** (그건 TLS)

[△ 2023 지방직 18번](#): SSH 전송 계층 프로토콜이 제공하지 않는 것 = **논리 채널 다중화** (그건 연결 프로토콜)

8.7 무선 LAN 보안 (WEP → WPA → WPA2 → WPA3)

표준	암호	무결성	키관리	약점
WEP	RC4	CRC-32	고정키	IV 짧음, 키 노출
WPA	RC4 + TKIP	Michael	동적	TKIP 취약점
WPA2	AES-CCMP	CCM	IEEE 802.11i	KRACK
WPA3	AES + SAE(Dragonfly)	GCMP	PFS	최신

모드: - WPA-개인: PSK(Pre-Shared Key) 기반 - WPA-엔터프라이즈: RADIUS 서버 + EAP

[△ 2023 국가직 20번](#): WEP 약점 보강은 IEEE(802.11i)가 정의, IETF X

8.8 방화벽

유형	특징
패킷 필터링	OSI 3·4계층, IP·포트로 필터링
상태 기반(Stateful)	세션 상태 추적
응용 계층(Proxy)	7계층, 콘텐츠 검사
회선 게이트웨이	SOCKS 등

구성: 베스천 호스트, DMZ, 스크리닝 라우터

8.9 침입탐지/방지

- **IDS**(탐지만), **IPS**(차단까지), **WAF**(웹 전용 응용 7계층)
- 탐지 방식: **오용 탐지**(시그니처), **이상 탐지**(통계, ML)
- **허니팟**: 공격자 유인 → 정보 수집 (방화벽 **내부망에도 설치 가능**) △

8.10 주요 공격 기법

SYN Flooding

- 3-way handshake 미완료(SYN만 보내고 ACK 안 보냄) → **백로그 큐 고갈**
- 방어: SYN Cookie, 백로그 큐 확장

Smurf

- 발신지를 **피해자 IP**로 위조한 ICMP Echo Request를 **브로드캐스트** → 전 호스트가 피해자에 응답

Land 공격

- **발신지 IP = 목적지 IP** 동일한 패킷 → 무한 루프
- △ 2023 지방직 12번: Land = “발신지와 목적지가 같은 패킷”

Ping of Death

- 65,535 byte 초과 ICMP → 재조립 시 오버플로

Teardrop

- **IP 패킷 조각(fragment)의 순서·오프셋 조작** → 재조합 오류
- △ 2026 국가직 13번: 정답 ②

Slowloris

- HTTP 헤더만 천천히 전송 → 서버 연결 점유

HTTP GET Flooding

- 정상 HTTP 요청 대량 발생 → 서버 자원 고갈

Pharming

- 호스트 파일·DNS 조작 → 가짜 사이트 유도 (DoS 아님) △ (2024 지방직 2번)

ARP 스푸핑

- ARP 캐시에 위조 MAC 주입 → 패킷 가로채기 (스니핑 + MITM)

DNS 스푸핑

- 위조 DNS 응답으로 가짜 사이트 유도, **UDP 기반** △ (2024 지방직 11번 — “TCP”가 X)
- 방어: **DNSSEC** (DNS 데이터 디지털 서명)

TCP 세션 하이재킹

- TCP **시퀀스 번호** 예측·제어 → 인증된 세션 탈취

스니핑

- 스위치 환경에서도 **ARP 스푸핑/스위치 재밍**으로 가능 △ (2022 국가직 19번)

MITM (중간자)

- 공개키 가로채기·교환 → 양측을 속임
- △ 2025 국가직 8번: 공개키 가로채기 시나리오 = MITM

포트 스캔

방식	특징
TCP Connect	완전한 3-way, 로그 남음
TCP Half-Open(SYN)	SYN→SYN+ACK 받으면 RST , 로그 안 남음 ⚠
FIN/NULL/X-MAS	비표준 플래그, 닫힌 포트→RST, 열린 포트→무응답
UDP	닫힌 포트→ICMP Port Unreachable

⚠ 2025 지방직 2번: TCP 포트 스캔에서 닫힌 포트 응답이 “ICMP Port Unreachable”이 X (그건 UDP 스캔)

제9장 애플리케이션 보안

9.1 웹 공격 [핵심표]

공격	설명	방어
SQL Injection	입력값에 SQL 문 삽입	Prepared Statement, 입력 검증
XSS	악성 스크립트 브라우저 실행	출력 인코딩, CSP
CSRF	인증된 사용자가 의도치 않은 요청	CSRF 토큰, Referer 검증
SSRF	서버가 내부망 요청하게 유도	화이트리스트, 메타데이터 차단
버퍼 오버플로	길이 검증 누락	카나리, ASLR, NX
파일 업로드	악성 스크립트 업로드·실행	확장자·MIME·매직넘버 검증
디렉토리 트래버설	../ 경로 조작	경로 정규화

XSS 유형

- **Reflected**: 요청에 포함된 스크립트가 즉시 응답에 반영
- **Stored**: 서버 DB에 저장되어 다른 사용자에게 노출
- **DOM-based**: 클라이언트 측 JS가 DOM 조작 중 실행

CSRF 시나리오 (2025 국가직 14번)

“공격자가 사용자에게 악의적 링크 클릭 유도 → 사용자 브라우저가 인증 쿠키 포함 **POST 요청** → 페이지 내용 변경” → **POST + CSRF**

입력 검증 누락으로 발생하는 공격 X: HTTP GET Flooding △ (그건 DoS, 입력 검증과 무관, 2023 국가직 10번)

9.2 SSS(Server Side Script) 언어

- **해당**: PHP, ASP, JSP
- **해당 X**: IIS (그건 **웹 서버**, MS) △ (2023 국가직 1번)

9.3 쿠키 처리

- **요청** 메시지의 **헤더** 라인을 통해 클라이언트→서버 쿠키 전달
- **응답** 메시지의 **헤더**(상태 라인 X) △ (2023 국가직 17번)
- **Set-Cookie 헤더**로 서버가 클라이언트에 쿠키 설정

9.4 SET (전자상거래)

- 신용카드 결제 보안 프로토콜
- **이중 서명** (제6장 참조)
- 상점 등록: 인증 허가 기관에 등록
- **고객 등록**: **인증기관**을 통해 (지불 게이트웨이 X) △ (2022 국가직 9번)

9.5 S/MIME (RFC 8551)

데이터 콘텐츠 유형

유형	기능
Signed-Data	전자서명
Enveloped-Data	기밀성 (암호화) 전용
Auth-Enveloped-Data	기밀성 + 인증
Compressed-Data	압축

△ 2025 국가직 15번: 기밀성만 = **Enveloped-Data**

S/MIME 알고리즘 짝 (2025 지방직 20번)

- **DSS — 전자서명** ✓

- ElGamal — 키 교환 (서명 가능하지만 메시지 인증 X)
- AES — 메시지·세션키 암호화 (전자서명 X)
- RSA — 키 교환·서명 (메시지 암호화로는 안 씀, 세션키 암호화)

9.6 DRM (Digital Rights Management)

- 디지털 콘텐츠 불법 복제·유포 방지, 저작권자 권리 보호
- 구성: 콘텐츠 암호화, 라이선스 관리, 사용 제어
- △ (2024 국가직 20번)

9.7 스테가노그래피

- 원본 파일에 정보 **삽입 + 존재 자체 은닉**
 - 암호학(Cryptography)은 내용은 숨기되 존재는 노출
-

제10장 정보보호 관리

10.1 ISMS-P 구조

3개 영역 + 항목 수

영역	항목 수	분야
관리체계 수립 및 운영	16개	PDCA 4단계
보호대책 요구사항	64개	12개 분야
개인정보 처리 단계별 요구사항	22개	6단계

관리체계 수립 및 운영 (PDCA)

단계	영역
Plan	관리체계 기반 마련
Do	위험 관리
Check	관리체계 운영
Act	관리체계 점검 및 개선

△ 2026 국가직 12번: 순서 = (다)→(가)→(나)→(라) = 기반마련→위험관리→운영→점검개선

△ 2024 국가직 19번: “조직 업무 특성에 따라 자산 분류, 정보흐름 파악·문서화, 위험 평가 결과로 보호대책 선정·이행계획·승인” → 위험 관리

보호대책 요구사항 12개 분야 (64개 항목)

- 1. 정책, 조직, 자산 관리
- 2. 인적 보안
- 3. 외부자 보안
- 4. 물리 보안
- 5. 인증 및 권한 관리
- 6. 접근 통제
- 7. 암호화 적용
- 8. 정보시스템 도입 및 개발 보안
- 9. 시스템 및 서비스 운영관리
- 0. 시스템 및 서비스 보안관리

- 1. 사고 예방 및 대응
- 2. 재해 복구

△ 2026 국가직 16번: “정보주체 권리보호”는 보호대책 분야 X (그건 개인정보 처리단계별 요구사항)

인증 및 권한관리 세부 (4개)

- 사용자 계정 관리, 비밀번호 관리, 특수 계정·권한 관리, 접근권한 검토
- △ 2025 국가직 12번: “정보시스템 보호”는 인증/권한관리 X (그건 접근통제 등)

외부자 보안 세부 항목 (2024 지방직 18번)

- 외부자 현황 관리, 외부자 계약 시 보안, 외부자 보안 이행 관리, 외부자 계약 변경 및 만료 시 보안
- X “보호 구역 지정” (그건 물리 보안)

사고 예방 및 대응 (2023 지방직 20번)

- ✓ 취약점 점검 및 조치
- ✓ 이상행위 분석 및 모니터링
- X 백업 및 복구 관리 (시스템 운영관리)
- X 재해 복구 시험 및 개선 (재해 복구)

10.2 위험 분석 접근법

방법	특징	장단점
기준선 접근법	표준 체크리스트	빠름, 단순 / 조직 특성 미반영
비정형 접근법	전문가 지식·경험	신속, 저비용 / 편견 위험 △
상세 위험 분석	자산·위협·취약점 분석	정확 / 시간·비용 多
복합 접근법	고위험 영역=상세, 나머지=기준선	균형 / 분류 어려움

정성적 분석: 델파이법, 시나리오법, 순위결정법, 브레인스토밍 (정량적 X) △ (2024 국가직 12번)

정량적 분석: 과거 자료 분석, 확률 분포법, 수학 공식, ALE 계산

△ 2026 국가직 7번: “전문가 집단 구성 + 토론” → 델파이법

10.3 ALE (연간 기대 손실) 계산

SLE (Single Loss Expectancy) = 자산 가치 × 노출 계수 (EF)
ALE = SLE × ARO (연간 발생률)

예: 자산 1억, EF 0.3, ARO 0.5 → SLE=3,000만, ALE=1,500만원

10.4 위험 처리 방법

방법	정의
수용(Acceptance)	위험 받아들이고 잠재 손실 감수
감소(Reduction)	통제·대책 적용
회피(Avoidance)	위험 행위·시스템 수행 안 함 (자산 구조·사용 변경)
전가(Transfer)	보험, 외주 계약 △ (2025 지방직 8번)

10.5 정보보호 평가 기준

기준	발행	특징
TCSEC	미국 (Orange Book, 1985)	A1>B3>B2>B1>C2>C1>D, 기밀성 중심
ITSEC	유럽 (1991)	F+E 결합, 기능성·보증 분리
CC(Common Criteria)	ISO 15408	EAL 1(최저) ~ EAL 7(최고) △
ISO/IEC 27001	국제 ISMS 표준	조직 자산·정보 보호 관리체계

ISO 27001 통제영역 (14개): 정보보호 정책, 정보보호 조직, 인적자원, 자산 관리, 접근 통제, 암호화, 물리·환경, 운영, 통신 보안, 시스템 획득·개발, 공급자 관계, 보안사고 관리, 사업연속성, 준거성

△ 2022 국가직 15번: “IT 재해복구”는 27001 통제영역 X (사업연속성으로 포함은 되나 별도 영역 아님)

CC의 보증 요구사항 (2024 국가직 8번): 개발, 가이드 문서, 생명주기, 시험, 취약점 평가 — “암호 지원, 식별·인증, 사용자 데이터 보호”는 기능 요구사항

△ 2024 지방직 13번: CC의 평가보증등급 EAL 1이 최저, 7이 최고 (1이 최고라는 표현이 X)

10.6 디지털 포렌식 원칙

원칙	정의
정당성	적법 절차로 입수 (위법 수집 증거 무효)
재현성	같은 조건에서 같은 결과
신속성	휘발성 정보 신속 수집
연계 보관성(Chain of Custody)	획득→이송→분석→보관→법정 제출 추적성
무결성	위·변조 없음 증명

△ 2024 국가직 15번: “획득→이송→분석→보관→법정 제출 추적성” = 연계 보관성

△ 2023 국가직 3번: “연계성=위변조 안 됨 증명”이 X (그건 무결성)

대검찰청 디지털 증거 수집·분석 규정 (2026 국가직 11번): - 적법절차 준수, 신뢰성 유지, 원본성 유지 - X “기밀성 유지” (오답)

제11장 정보보호 법규

11.1 법률별 소관 부처

법률	소관 부처
개인정보 보호법	개인정보 보호위원회
정보통신망법	과학기술정보통신부, 방송통신위원회
위치정보법	방송통신위원회 △ (과기정통부 X)
공공기관의 정보공개에 관한 법률	행정안전부
전자서명법	과학기술정보통신부
정보통신기반 보호법	과학기술정보통신부
신용정보법	금융위원회

△ 2025 국가직 13번: 위치정보법 소관은 **방통위**, “과기정통부”가 X

11.2 개인정보 보호법 핵심 조문

제2조 정의

- **개인정보**: 살아 있는 개인에 관한 정보 (사망자 X) △ (2025 국가직 6번)
- **민감정보** (시행령 제18조): 사상·신념, 노조·정당 가입, 정치적 견해, 건강, 성생활, 유전정보, 범죄경력, 인종·민족, **개인 식별 생체정보**
- X “특정 개인을 알아보지 못하도록 기술적 수단으로 생성한 정보” (2024 지방직 10번)

제3조 개인정보 보호 원칙

- 처리 목적 명확, 최소 수집
- 정확성·완전성·**최신성** 보장
- **공개**해야 함 (비공개 X) △ (2022 국가직 14번)
- 익명·가명: **익명 우선** → 익명으로 안 되면 가명 △ (2025 국가직 10번 — 가명 우선이 X)

제4조 정보주체의 권리

1. 처리에 관한 정보 제공받을 권리
2. 동의 여부·범위 선택·결정 권리
3. 처리 여부 확인, 열람 권리
4. 처리 정지·정정·삭제·파기 요구 권리
5. 피해 구제 받을 권리
6. **완전히 자동화된 결정 거부·설명 요구 권리** (2023.3 신설)

△ 2024 국가직 14번: “자동화 처리 결정을 **승인**”이 X (실제는 **거부·설명 요구**)

제15조 개인정보의 수집·이용 (6가지 사유)

1. **정보주체의 동의**
2. **법률 특별 규정 / 법령상 의무**
3. **공공기관의 소관 업무**
4. **정보주체와의 계약 체결·이행**
5. 정보주체 또는 제3자의 급박한 생명·신체·재산 이익
6. 개인정보처리자의 정당한 이익 (우선)

△ 2023 국가직 18번: “**공공기관과의 계약**”이 X (실제는 “정보주체와의 계약”)

제17조 개인정보의 제3자 제공 (동의 시 알릴 사항)

1. 제공받는 자
2. 제공받는 자의 이용 목적
3. **제공하는 개인정보 항목**
4. **보유·이용 기간**
5. 동의 거부 권리 및 거부 시 불이익

△ 2025 지방직 17번: “동의에 따른 이익”은 알릴 사항 X

제26조 업무 위탁

- 수탁자는 위탁 범위 **초과** 이용·제공 **금지** △ (2022 국가직 10번 — “초과 이용 가능”이 X)
- 수탁자=처리자 소속 직원으로 간주 (손배책임)

제28조의2 가명정보의 처리

- 통계작성, 과학적 연구, 공익적 기록보존: 동의 없이** 가명정보 처리 가능
- 제3자 제공: 특정 개인을 알아보기 위한 정보 **포함 금지** △ (2023 국가직 5번)

제30조 개인정보 처리방침 (포함 사항)

- 처리 목적
- 처리 및 보유 기간
- 제3자 제공
- 처리위탁
- 정보주체와 법정대리인의 권리·의무·행사 방법**
- X “성명·부서명·전화번호” 등 연락처는 별도 조항(보호책임자) △ (2024 국가직 13번)

제31조 개인정보 보호책임자

수행 업무: 1. 보호 계획 수립·시행 2. 처리 실태·관행 정기 조사·개선 3. 처리 관련 고충 처리 4. **내부통제시스템 구축** 5. 처리방침 수립·변경·시행 6. 보호 관련 자료 관리 7. 처리 위탁 시 관리·감독 - X “**처분에 관한 사항**” (그건 보호위 또는 행정처분 기관) △ (2024 지방직 20번)

제35조 개인정보 열람

제한·거절 사유: 1. 법률에 따라 열람 금지·제한 2. 다른 사람의 생명·신체 위해 또는 **재산·이익 부당 침해** 3. 공공기관의 ① 조세 부과·징수·환급, ② 평가·심사, ③ 입시 등 시험, ④ 보상금·급부금 산정, ⑤ 감사·조사 등 중대 지장 초래 - X “처리자의 정당한 이익” (열람 제한 사유 X) △ (2026 국가직 19번)

개인정보 보호위원회 위원 자격 (2026 국가직 18번)

자격 요건 (위원장·부위원장 제외): 1. 개인정보 보호 업무 담당 **고위공무원단 소속 공무원**의 직 또는 **3급 이상 공무원의 직**에 있었던 사람 2. 판사·검사·변호사 **10년 이상** 재직 3. 공공기관·단체로부터 추천받은 사람으로 보호 업무 **3년 이상** 담당 4. 대학 **부교수 이상 5년 이상** 재직 △ (“3년 이상”이 X)

제39조 손해배상

- 정보주체는 손해배상 청구 가능
- 법정손해배상:** 300만원 이하 (실손해 입증 곤란 시)
- 징벌적 손해배상:** 고의·중과실 → **손해의 5배 이하**

가명정보 처리 기술 (2025 지방직 19번)

- 총계 처리:** 평균·최댓값·최솟값·최빈값·중간값
- 일반 라운딩:** 올림·내림·반올림
- 로컬 일반화:** 특정 열 항목 일반화
- 순서보존 암호화: 암호문 복호화 가능** (옳지 않은 보기 ㉔: “복호화 적용 불가능” X)
- 동형 암호화:** 암호화된 상태로 연산 가능 △ (2024 지방직 15번)

제21조 개인정보의 파기 (2025 지방직 15번)

- 보유 기간 경과·목적 달성 시 **지체 없이** 파기
- 복구·재생 불가하도록 조치
- 다른 법령으로 보존 시 분리 저장·관리
- 파기 방법·절차는 **대통령령**으로 정함 (“총리령”이 X) △

11.3 정보통신망법 핵심 조문

제2조 정의

- 정보통신서비스 제공자:** 전기통신사업자 + 영리 목적 정보 제공·매개자
- 통신과금서비스이용자:** 통신과금서비스를 **이용하여 재화 등을 구입**하는 자 (단순 정보통신 이용자 X) △ (2022 국가직 18번)
- 침해사고:** 해킹·바이러스·논리폭탄·메일폭탄·DoS·고출력 전자기파 등 공격

규정 사항 vs 미규정

정보통신망법 규정 0: - 정보통신망의 표준화 및 인증 - 정보통신망의 안정성 확보 - 집적된 정보통신시설의 보호 - 침해사고 대응

규정 X (다른 법): - 고정형 영상정보처리기기 설치·운영 제한 → 개인정보 보호법 △ (2023 지방직 5번) - 위치정보 → 위치정보법

제23조의3 본인확인기관 지정

- 지정 기관: 방송통신위원회 △ (2023 국가직 8번)
- 심사 항목: 안전성, 수행 능력(기술·재정), 설비 규모 적정성

제45조 정보통신망 정보보호지침

포함 사항: - 정보통신망연결기등 인증 관련 사항(물리 X) △ (2024 국가직 18번) - 정보 불법 유출·위변조·삭제 방지 기술적 보호조치 - 지속적 이용 위한 기술·물리적 보호조치 - 인력·조직·경비 등 관리적 보호조치

제48조의4 침해사고 원인 분석

- 정보통신서비스 제공자는 분석 + 피해 확산 방지·대응·복구·재발 방지 조치
- 과기정통부장관: 권고 가능, 자료 보존 명령 가능
- 민·관 합동조사단: 침해사고 조사 시 수집한 자료는 원인 분석이 끝나면 폐기 (재발 방지 목적으로도 보존 X) △ (2023 지방직 13번)

11.4 기타 법률

전자서명법

- 평가기관 → 전자서명인증사업자 평가 → 인정기관에 결과 제출
- 인정 받으려는 사업자: 국가기관·지자체·공공기관에 한정 X (민간도 가능) △ (2023 지방직 8번)

정보보호제품 평가·인증 (2024 지방직 13번)

- 근거: 지능정보화 기본법 제58조
- 인증기관: 국가보안기술연구소(NSR)
- 공통평가기준(CC): EAL 1(최저)~EAL 7(최고)
- 보호 프로파일(PP): 사용 환경에서 필요한 보안기능·보증 요구사항 서술

보안관제 전문기업 지정 기준 (2026 국가직 20번)

- 법인 설립 이후 5년 이상
- 자기 자본 20억원 이상
- 보안관제 수행능력 평가 70점 이상
- 자격 갖춘 기술인력 15명 이상 (고급 3명 이상, 중급 6명 이상 포함)

ISMS-P 인증심사원 (2022 국가직 20번)

- 자격 유효기간: 3년
- 보수교육 시간 이수 의무
- 등급: 심사원보 → 심사원 → 선임심사원(3회 이상 참여 + 심사일수 15일 이상)
- 자격 취소: 법령 위반, 인증신청인 동의 없이 정보 누설

11.5 GDPR (유럽)

정보주체 권리: - 정보를 제공받을 권리 - 열람권 - 정정권 - 삭제권 (잊혀질 권리) - 처리 제한 요구권 - 데이터 이동권 (다른 사업자에 전송) - 처리에 반대할 권리 - 자동화된 의사결정에 종속되지 않을 권리 (자동화 결정 거부할 권리는 있으나 “모든 의사결정” 거부 권리는 X) △ (2025 지방직 13번)

11.6 OECD 프라이버시 8원칙 (2024 지방직 17번)

원칙	영문	내용
수집 제한	Collection Limitation	합법·공정 수집 + 인지·동의
데이터 품질	Data Quality	목적 관련 + 정확·완전·최신
목적 명확화	Purpose Specification	수집 전 목적 명시
이용 제한	Use Limitation	목적 외 이용 금지
안전 보호	Security Safeguards	분실·도난 대응
공개	Openness	정책·관행 공개
개인 참여	Individual Participation	본인 정보 확인·정정
책임	Accountability	책임 명시

제12장 bin출 함정과 신유형

12.1 자주 헛갈리는 매칭

헛갈림	정답
디피-헬만 = 대칭키?	비대칭키 (키 교환)
Biba = 임의적?	강제적, 무결성
BLP = 무결성?	기밀성
Pharming = DoS?	DNS·호스트 파일 조작 (DoS X)
FRR = 권한 없는 사람 성공?	권한 있는 사람 실패 (FAR가 권한 없는 사람 성공)
HKEY_CURRENT_CONFIG = 실시간 성능?	HW 프로파일
위치정보법 = 과기정통부?	방통위
CC EAL 1 최고?	EAL 7이 최고
정보보호 처리방침 = 공개 X?	공개해야 함
가명 우선 처리?	익명 우선, 익명 불가 시 가명
자동화 결정 승인 권리?	거부·설명 요구 권리

12.2 2026 신유형 예고

CAPTCHA

- 컴퓨터와 사람 구분 **자동 튜링 테스트**
- 이미지·왜곡 문자·잡음 사운드 사용
- 기밀성 보장 위한 암호 X** (인증·봇 차단 목적) △

NAC (Network Access Control)

- IP 관리 시스템에서 발전
- MAC 주소 기반** 접근 제어·인증
- 정책 부합 단말기만 자원 이용 허용

제로 트러스트 (Zero Trust)

- “Never Trust, Always Verify”
- 모든 접근에 인증·인가, 최소 권한, 마이크로 세그멘테이션
- 구현: **ZTNA**(Zero Trust Network Access) — VPN 대체

SASE

- Secure Access Service Edge
- 네트워크(SD-WAN) + 보안(SWG, CASB, ZTNA, FWaaS) 통합 클라우드 서비스

CASB

- Cloud Access Security Broker
- SaaS 가시성·DLP·위협 차단

CSPM

- Cloud Security Posture Management
- 클라우드 설정 오류 자동 탐지·교정

SIEM / SOAR

- SIEM**: 로그 통합·이벤트 상관 분석
- SOAR**: 자동 대응·플레이북

EDR / XDR

- **EDR**: 엔드포인트 행위 분석·탐지·대응
- **XDR**: 엔드포인트+네트워크+클라우드 통합

PQC (Post-Quantum Cryptography)

- 양자컴퓨터에 안전한 암호
- **NIST 표준 (2024.8)**: ML-KEM(키 교환, Kyber 기반), ML-DSA(서명, Dilithium 기반), SLH-DSA(SPHINCS+ 기반)
- RSA·ECC는 **Shor 알고리즘**으로 깨짐

AI 보안 위협

- **데이터 포이즈닝**: 학습 데이터에 악성 샘플 주입
- **적대적 공격 (Evasion)**: 추론 시 미세 변형으로 오분류
- **모델 추출 공격**: 쿼리로 모델 복제
- **멤버십 추론**: 학습 데이터 포함 여부 추측

블록체인

- **머클 트리 루트**: SHA-256 이진 트리 루트 해시, 크기 **32바이트** (64바이트 X) △ (2022 국가직 8번)
- **하이퍼레저 패브릭**: 허가형 프라이빗 블록체인, MSP, 체인코드, **PBFT/Raft 합의** (지분 증명 X) △ (2023 국가직 7번)
- **51% 공격**: 작업 증명에서 해시파워 과반 장악

마이데이터·자동화 결정

- **개인정보 전송요구권**(법 제35조의2)
- **자동화 결정 거부·설명 요구권**(법 제37조의2)

12.3 시험장 직전 체크리스트

✓ **정답 분포 추정**: 보통 ①②③④ 각 5개씩 ± 1~2 ✓ **“옳지 않은” 문제 표시**: 헛갈리지 않게 동그라미 ✓ **숫자·계산 정확**: AES 라운드, SHA-512 블록, EAL 1~7, 5년·20억·15명 ✓ **법령 단어 합정**: “공공기관과의” vs “정보주체와의”, “익명·가명” 우선순위 ✓ **빈출 매칭**: BLP=기밀, Biba=무결, Clark-Wilson=상업 무결 ✓ **신유형 키워드**: CAPTCHA, NAC, 제로트러스트, PQC, AI 포이즈닝

END OF DOCUMENT